🔐 GRC Risk Assessment Report – Fintech Environment

1. Executive Summary

This report presents a comprehensive Governance, Risk, and Compliance (GRC) assessment for a simulated fintech organization operating in a cloud-based environment and handling sensitive customer and PCI data.

The assessment identified multiple high and critical risks related to data protection, access control, cloud security, and phishing threats. Several key security controls, including multi-factor authentication (MFA), role-based access control (RBAC), and centralized monitoring, were found to be either partially implemented or not implemented.

Additionally, the organization lacks sufficient detection capabilities, particularly in real-time monitoring and alerting, increasing exposure to data breaches and unauthorized access.

To mitigate these risks, this report recommends enforcing MFA across all users, strengthening identity and access management (IAM), implementing a SIEM solution for real-time monitoring, and securing backup systems against ransomware through immutability.

Overall, while foundational controls exist, significant improvements are required to align with industry best practices and reduce overall risk exposure.

2. Methodology

The assessment was conducted following a structured risk management approach aligned with the NIST Cybersecurity Framework.

Key Steps:

- Identification of critical assets (data, systems, infrastructure)
- Mapping of threats and vulnerabilities
- Risk evaluation using Likelihood × Impact methodology

- Identification and classification of controls:
  - Preventive
  - Detective
  - Corrective
- Gap analysis to identify missing or weak controls
- Development of remediation recommendations based on risk priority

3. Scope

The assessment covered the following assets:

- Customer Database
- PCI Database
- Cloud Infrastructure
- Web Application
- Employee Devices
- Email System
- Backup Systems

4. Key Risks Identified

The following risks were identified as the most critical:

Data Breach

- Affects Customer Data and PCI Database
- Caused by weak access controls and lack of RBAC

Cloud Misconfiguration

- Overly permissive IAM roles
- Lack of proper monitoring and alerting

Phishing & Business Email Compromise (BEC)

- Low user awareness
- Weak email filtering controls

Weak Identity and Access Management

- Lack of MFA enforcement
- No formal authentication policy

Ransomware Risk

- Backup systems not immutable
- Lack of monitoring and alerting

5. Controls Overview

The organization has implemented a mix of security controls categorized as follows:

Preventive Controls

- Multi-Factor Authentication (MFA)
- Encryption
- Web Application Firewall (WAF)
- IAM Hardening
- Security Awareness Training

Detective Controls

- SIEM Monitoring & Alerting
- Log Monitoring
- Cloud Monitoring
- Email Monitoring
- Database Activity Monitoring

Corrective Controls

- Immutable Backups
- Backup Monitoring

6. Gap Analysis Summary

The gap analysis revealed several weaknesses:

✕ Not Implemented

- SIEM Monitoring
- Cloud Monitoring Alerts
- RBAC
- Backup Monitoring
- User Reporting Processes

⚠ Partially Implemented

- MFA (not enforced for all users)
- IAM controls (overly permissive roles)
- Email security filtering
- Logging without alerting

These gaps significantly increase the likelihood and impact of security incidents.

7. Recommendations

The following actions are recommended based on priority:

🔥 Critical Actions

- Implement SIEM with real-time alerting
- Enforce RBAC across all systems
- Enable immutable backups
- Deploy cloud monitoring and alerting

⚠ High Priority

- Enforce MFA for all users
- Implement least privilege access controls
- Strengthen email security gateway
- Centralize log management

Medium Priority

- Establish continuous security awareness training
- Implement user incident reporting processes
- Automate monitoring and alerting

8. Conclusion

This assessment demonstrates that while the organization has a foundational security posture, it requires significant improvements in control enforcement, monitoring, and governance.

By addressing the identified gaps and implementing the recommended controls, the organization can reduce its risk exposure, improve detection capabilities, and align with industry best practices.

9. Skills Demonstrated

- Risk Assessment & Analysis
- Threat & Vulnerability Identification
- Control Design (Preventive, Detective, Corrective)
- Gap Analysis
- Security Governance
- Framework Alignment (NIST CSF)

10. Final Note

This project reflects a practical, real-world application of GRC principles in a fintech environment and demonstrates the ability to analyze, prioritize, and mitigate cybersecurity risks effectively.